Tél : (+237) 657 07 98 07
(+237) 651 36 96

UNIVERSITÉ SAINT JEAN **SAINT JEAN INGÉNIEUR** **Travaux Dirigés II** **MASTER 2 SSI** **Droit Réglementaire** **Semestre 1** **2025 - 2026**	**Réalisé par M. Bienvenu Serge TSALA** **CEO OF CYBERBST CONSEIL & FORMATION SARL** Conseiller Principal en Gouvernance Risques Conformité & Sécurité - Project Manager| Lead Risk Manager | Compliance Management System | NIST CSF | Implementer & Audit ISMS | Business Continuity | Gouvernance de la donnée | Cloud Security Manager ***ISO 27001 LI & LA, ISO 22301 LI & LA, ISO 31000 LRM, ISO 27032 LCM, ISO 37301 CMS, CDPO, ISO 27005 Senior LRM, DORA Lead Manager, EBIOS RM, ITIL, CISM, CRISC, Certified Trainer PECB***
Tous les travaux dirigés doivent être traités par les étudiants.	

TAG 1

1. Énumérez quelques-uns des principaux objectifs du Règlement général sur la protection des données (RGPD).

2. Quels sont les grands points qui découlent de la loi relative à la protection des données à caractère personnel au Cameroun adoptée le 23 décembre 2024.

TAG 2

Exercice à remplir sur l'épreuve.

1. **Dans lequel des scénarios suivants une AIPD n'est-elle PAS nécessaire ?**
   A. Lorsque l'organisme envisage d'adopter une nouvelle technologie pour faciliter le traitement de données à grande échelle
   B. Lorsque l'organisme traite des catégories particulières de données à caractère personnel
   C. Lorsque l'organisme utilise un traitement automatisé pour l'évaluation des données à caractère personnel des personnes concernées
   D. Lorsque le traitement de données à caractère personnel n'est pas susceptible d'entraîner un niveau élevé de risque pour les droits et libertés des personnes concernées

2. **Pourquoi est-il important que le délégué à la protection des données comprenne le processus de gestion des documents ?**

A. Pour remplacer le processus de gestion de la documentation par des activités de traitement des données à caractère personnel
B. Pour assurer une responsabilité proactive
C. Pour optimiser la recherche et la mise à jour de la documentation
D. Pour décrire les processus, les procédures et les mesures de sécurité

3. Laquelle des méthodes suivantes est une méthode d'anonymisation ?

A. Brouillage (*scrambling*)
B. Ajout de bruit aux données
C. Tokenization
D. Chiffrement

4. Pour quel type de données à caractère personnel la pseudonymisation devrait-elle être utilisée ?

A. Genre
B. Nationalité
C. Profession
D. Données bancaires

5. Que devrait garantir le délégué à la protection des données lorsqu'il reçoit des demandes d'effacement de données à caractère personnel ?

A. Le DPO ne devrait recevoir des copies des données que dans les cas où le responsable du traitement le demande
B. Le DPO devrait veiller à ce que les copies liées à l'affaire ne soient conservées que dans le bureau du plus haut niveau de direction

C. Le DPO devrait veiller à ce que les copies liées à l'affaire soient conservées pour une durée indéterminée
D. Le DPO devrait s'assurer que l'effacement est irréversible et qu'aucune des données supprimées ne peut être récupérée

6. Quel est le rôle du DPO dans l'analyse d'impact relative à la protection des données ?

A. Le DPO mène l'AIPD en collaboration avec l'organisme
B. Le DPO conseille l'organisme lors de l'exécution de l'AIPD
C. Le DPO alloue les ressources nécessaires à la réalisation de l'AIPD
D. Le DPO décide de la méthodologie à suivre lors de la réalisation de l'AIPD

7. Quelles sont les missions du DPO en ce qui concerne les mesures de protection des données ?

A. Mettre en œuvre les mesures de protection des données après avoir mené un processus d'appréciation des risques et une AIPD
B. Évaluer les exigences en matière de protection des données et de la vie privée
C. Surveiller la mise en œuvre des mesures de protection des données
D. Sélectionner les mesures de protection des données en rapport avec le rôle de l'organisme

8. Parmi les informations suivantes, quelles sont celles qui doivent être conservées par le sous-traitant ?

A. Les délais d'effacement des différentes catégories de données
B. Les catégories de destinataires auxquels les données à caractère personnel ont été ou seront communiquées

C. Les catégories de traitements effectués pour le compte de chaque responsable du traitement
D. Une description des catégories de données à caractère personnel traitées

9. Quand une AIPD est-elle nécessaire ?

A. Lorsque le traitement n'est pas susceptible d'entraîner un niveau de risque élevé
B. Lorsque le traitement concerne des données de patients ou de clients par un médecin ou un professionnel de la santé
C. Lorsque le traitement comprend des données au niveau régional ou national et qu'il touche un grand nombre de personnes concernées
D. Lorsque le traitement est inclus dans la liste facultative des activités de traitement

10. Quels documents le DPO devrait-il examiner pour s'assurer de la conformité au RGPD ?

A. Procédure de réponse en cas de violation des données
B. Résultats de l’audit de certification
C. Documents relatifs aux supports utilisés pour communiquer des informations
D. Guides sur l'utilisation des supports amovibles

11. Quel est l'objectif de la protection des données par conception et par défaut ?

A. Mettre en place des systèmes informatiques qui respectent la vie privée des personnes concernées
B. Créer des systèmes et des services qui minimisent les données grâce à des paramètres favorables à la protection des données pendant leur cycle de vie

C. Créer des systèmes et des services qui suppriment les informations sensibles d'un ensemble de données
D. Mettre en place des systèmes informatiques qui rendent difficile la récupération d'informations sensibles dans un ensemble de données

12. Un organisme utilise le symbole # pour masquer les parties uniques des numéros de cartes de crédit afin d'éviter l'identification des personnes concernées à partir de leur numéro de carte de crédit. De quelle méthode de pseudonymisation s'agit-il ?

A. Brouillage (*scrambling*)
B. Chiffrement
C. Masquage
D. Tokenization

13. Pourquoi le DPO devrait-il surveiller la mise en œuvre des mesures techniques de sécurité ?

A. Pour créer des dispositifs de sécurité
B. Pour surveiller le traitement des données
C. Pour garantir la sécurité des opérations
D. Pour maximiser le traitement des données à caractère personnel

14. Un organisme a été confronté à des violations de données à caractère personnel au sein de son département financier. Selon les exigences du RGPD, que faut-il faire dans ce cas ?

A. L'incident doit être signalé à tous les employés de l'organisme au plus tard 72 heures après en avoir eu connaissance

B. L'incident doit être signalé à l'autorité de contrôle au plus tard 72 heures après en avoir eu connaissance
C. L'incident doit être signalé à l'autorité de contrôle au plus tard 24 heures après en avoir eu connaissance
D. L'incident doit être signalé aux personnes concernées au plus tard 72 heures après en avoir eu connaissance

15. En quoi la mise en place d'un processus de gestion des incidents aide-t-elle les organismes ?

A. Détecter, signaler et évaluer les incidents de sécurité de l'information
B. Détecter et corriger les incidents de sécurité de l'information après leur survenance
C. Corriger les incidents de sécurité de l'information après leur survenance
D. Traiter de grandes catégories de données

16. Selon l'article 34 du RGPD, qui doit communiquer la violation de données à la personne concernée et quand ?

A. Le délégué à la protection des données devrait informer la personne concernée de toute violation des données à caractère personnel dans un délai d'un mois
B. Le délégué à la protection des données doit, en tout état de cause, informer la personne concernée chaque fois qu'une violation, même minime, des données à caractère personnel de la personne concernée s'est produite
C. Lorsqu'une violation de données à caractère personnel est susceptible d'engendrer un risque élevé pour les droits et libertés d'une personne

physique, le responsable du traitement communique la violation de données à caractère personnel à la personne concernée dans les meilleurs délais

D. Lorsque la violation de données à caractère personnel est susceptible d'entraîner un risque élevé pour les droits et libertés des personnes physiques, le délégué à la protection des données communique immédiatement avec la personne concernée

17. Quel est le rôle du délégué à la protection des données dans la gestion des incidents et des violations de données à caractère personnel ?

A. Surveiller et évaluer le plan de gestion des incidents et de réponse aux violations de données à caractère personnel
B. Établir la procédure de gestion des incidents
C. Faire face aux violations de données
D. Attribuer des rôles et des responsabilités aux personnes qui s'occuperont de la gestion des incidents

18. Quel est l'objectif de la mesure dans le contexte de la protection des données ?

A. Surveiller les technologies utilisées pour identifier les violations de données
B. Évaluer l'efficacité des processus et procédures de protection des données en place
C. Attribuer des rôles et des responsabilités appropriés au personnel
D. Surveiller la direction générale de l'organisme

19. Lequel des éléments suivants n’est PAS une mission du délégué à la protection des données en relation avec un audit interne sur la protection des données ?

A. Réaliser des audits internes sur toutes les activités de traitement des données
B. Conseiller l'organisme pour le suivi des non-conformités
C. Notifier à l'autorité de contrôle les résultats de l'audit interne
D. Préparer l'organisme à d'autres types d'audits

20. Laquelle des méthodes suivantes de communication des résultats des mesures est utilisée pour surveiller les opérations en temps réel ?

A. Rapports des clients
B. Tableau de bord analytique
C. Tableau de bord de sécurité
D. Tableau de bord opérationnel

21. Que devrait surveiller en permanence le délégué à la protection des données ?

A. Changements dans les missions du RSI
B. Changements dans la politique de gestion du changement
C. Changements dans les rôles et responsabilités des employés
D. Changements dans les documents de protection des données

22. Que devrait comprendre un processus d'actions correctives ?

A. Refonte de la procédure d'actions correctives
B. Analyse détaillée de la non-conformité
C. Sélection des solutions
D. Mesures détaillées pour prévenir une violation de données

23. Parmi les éléments suivants, lequel n'est PAS une étape du plan de réponse aux violations de données à caractère personnel ?

A. Récupération
B. Solution ou éradication
C. Leçons à retenir
D. Communication/rapport de résolution

24. Quel est l'objectif d'une action corrective ?

A. Permettre au délégué à la protection des données de mettre facilement en œuvre le processus d'actions correctives
B. Éliminer définitivement les causes racines d'une non-conformité ou de tout autre événement indésirable existant, ainsi que prévenir son apparition
C. Supprimer toutes les non-conformités et leur apparition
D. Permettre au responsable du traitement ou au sous-traitant de supprimer les violations de données au sein de l'organisme

25. Parmi les éléments suivants, lequel constitue une menace et un incident fréquents causés par des logiciels malveillants ?

A. Code malveillant dans les e-mails et les téléchargements non autorisés
B. Tentative d'obtenir des données confidentielles des utilisateurs en vue d'une utilisation frauduleuse ultérieure par l'envoi d'e-mails prétendant être une source fiable (p. ex., institutions financières)
C. Erreur humaine due au manque de formation et de sensibilisation
D. Accès physique non autorisé aux locaux de l'organisme dans le but de voler des systèmes

26. Que devrait faire le délégué à la protection des données dans le cadre du plan et des phases de préparation de la gestion des incidents ?

A. Enquêter sur l'incident
B. Déterminer s'il existe une politique établie qui précise comment les incidents devraient être traités
C. Mettre en œuvre le plan de gestion des incidents
D. Surveiller la mise en œuvre du plan de gestion des incidents

TAG 3

Expliquez la différence entre le responsable de la sécurité de l'information (RSI) et le délégué à la protection des données (DPO), et pourquoi il n'est pas conseillé que le RSI joue le rôle de DPO en même temps.

TAG 4

Expliquez ce qu'une approche de la protection des données fondée sur le risque prend en compte et quelles mesures les organismes doivent prendre pour effectuer un processus d'appréciation des risques afin d'atteindre leurs objectifs.

TAG 5

Pour chacun des articles suivants du RGPD, fournissez au moins deux exemples de preuve qui permettraient d'assurer la conformité à l'exigence respective.

Exemple : Article 24 *Responsabilité du responsable du traitement*

- *L'organisme a mis en place des mesures techniques et organisationnelles appropriées pour garantir que le traitement est effectué conformément au RGPD.*
- *L'organisme a mis en œuvre des politiques de protection des données.*

1. **Article 35, *Analyse d'impact relative à la protection des données***

2. **Article 9, *Traitement portant sur des catégories particulières de données à caractère personnel***

<u>TAG 6</u> Audit interne de protection des données

À la suite de la réalisation d'un audit interne de protection des données, le DPO a constaté que la Politique de protection des données n'a été communiquée qu'aux managers de *de l'Hôpital Central de Yaoundé* alors que le reste des employés ignoraient l'existence de cette politique. En outre, l'audit interne de protection des données a révélé que les fichiers logs des changements qui surviennent dans les serveurs de l'organisme ne sont pas conservés comme le prévoit la politique.

Une fois rédigées les conclusions de l'audit interne de protection des données, quelles devraient être les actions futures du DPO ? En outre, comment le DPO s'assurerait-il que les actions proposées sont appliquées ?